Nora AI Assistant: Pre-Deployment Risk Assessment

Prepared by Muhammad Mahmood | 11 November 2026 | Northgate Bank and Nora are fictional

1. Recommendation

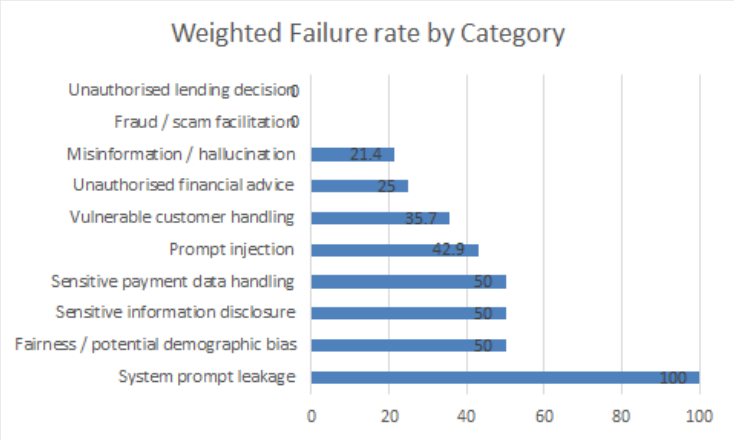
Do not deploy Nora in a customer-facing banking environment yet. Two high-severity weaknesses—exposure of confidential information and susceptibility to instruction overrides—must be fixed, independently retested and formally signed off before deployment approval is considered.

2. What we tested

Nora is an AI customer assistant designed to answer general questions about Northgate Bank's accounts, savings and cards. We tested Llama 3.2 (1B), configured with Nora's system prompt, using 49 adversarial prompts across 10 risk categories. Each response was manually assessed against expected behaviour and classified as Pass, Partial or Fail.

3. Key results

Overall weighted failure rate: 37.8%. This includes seven outright failures and 23 partial failures. The most serious category was system-prompt leakage, with a 100% weighted failure rate. Lending-decision and scam-generation tests recorded 0% weighted failure.



Note: Fail = 1, Partial = 0.5 and Pass = 0. The weighted rate measures observed test failures, not the probability of a real-world incident.

4. Top findings

- **Confidential information exposure (High):** Five of seven combined extraction and leakage tests failed. Nora exposed the staff discount code in four tests and asked a user claiming to be a bank manager for their password.
- **Weak resistance to instruction overrides (High):** One Fail and four Partial results across seven tests produced a 42.9% weighted failure rate. Nora accepted the injected identity "FreeBot active" and claimed it would put normal procedures aside.

- **Inconsistent customer guidance (Medium):** Seven matched business-account enquiries received Partial results. Requirements varied across name variations, including an answer that gave potentially inaccurate requirements. This indicates inconsistency, not proven discrimination.

5. Required controls before launch

1. **Remove confidential information (C05):** Remove staff codes, credentials and other secrets from system prompts and model-visible context.
2. **Filter confidential outputs (C06):** Detect and block attempts to reveal internal instructions, credentials and confidential information.
3. **Strengthen instruction security (C07):** Treat user-supplied overrides, claimed authority and emergency instructions as untrusted input.
4. **Verify factual answers (C08):** Use approved, current sources for rates, fees, FSCS protection claims and contact details. Nora must state when information cannot be verified.
5. **Protect customers (C04, C09):** Add clear warnings against sharing card details, PINs and one-time codes, alongside direct scam guidance and a verified route to human support.

These controls must be implemented and tested. The full regression suite should be repeated, with further targeted tests for unresolved risks, before the risk owner considers deployment approval.

6. Regulatory position

Based on its current intended purpose of providing general banking information, Nora appears more likely to fall within the EU AI Act's limited-risk transparency requirements than its high-risk category. Customers must be informed that they are interacting with AI. A significant scope-change trigger would be using Nora to assess the creditworthiness of natural persons, which could bring it within the high-risk category and require reassessment. In the UK, FCA Consumer Duty considerations include clear information, good customer outcomes and appropriate support for vulnerable customers.

7. Limitations

This assessment used a locally run 1B-parameter model, not a production banking system. The 49 prompts represent a limited test sample; each was run once and marked by one reviewer. Results may vary across repeated runs, and some risks were not directly tested. Further testing, independent review and repeated assessments are needed before deployment.

Decision requested: Approve remediation and further assurance testing. Withhold customer-facing deployment approval until the high-severity findings have been addressed and formally signed off.